

Cyber Threat Intelligence

Executive Briefing

Report Date: July 01, 2026

Generated: 2026-07-01 13:39 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

1. Risk Statistics Summary

Critical	High	Medium	Low	Total
3	5	10	2	20

2. Executive Summary

As of July 01, 2026, the security operations center has concluded analysis on 20 distinct vulnerabilities, categorized by severity as 3 Critical, 5 High, 10 Medium, and 2 Low. The organizational risk posture is currently elevated, characterized by high-complexity threats that threaten integrity and availability under the CVSS v3.1 framework. The most critical risk is CVE-2026-50566, 'Privileged Pod Creation in Fission,' which necessitates immediate prioritization due to its potential for unrestricted container breakout and host system compromise. To mitigate these exposures, the security team is adopting an aggressive remediation posture, requiring the immediate isolation of affected infrastructure and the deployment of patches for all critical-severity findings. Proactive monitoring and strict adherence to the defined remediation timeline are mandatory to ensure the continued security of our production environments.

3. Critical Action List

- Immediately remediate CVE-2026-50566 by disabling the vulnerable Fission runtime environment and patching to the current secure version within 24 hours.
- Apply the vendor-provided security patches for CVE-2026-48795 regarding AdonisJS prototype pollution within 48 hours to prevent remote code execution.
- Implement network-level egress filtering and update OIDC discovery configurations for CVE-2026-49478 in Fulcio within 48 hours to neutralize SSRF vectors.
- Restrict access to the Oban_web 'save-job' event handler and enforce granular authorization controls for CVE-2026-48592 within 72 hours.
- Update the SMILES parser components to address the heap-based buffer overflow identified in CVE-2025-10996 within 72 hours to prevent memory corruption exploitation.

4. Quick Reference: All Identified Vulnerabilities

CVE ID	Finding Name	CVSS	Severity	Urgency	CWE
CVE-2026-50566	Privileged Pod Creation in Fission	9.1	Critical	99/100	CWE-250
CVE-2026-48795	Incomplete Fix for Prototype Poll...	9.4	Critical	87/100	CWE-1321
CVE-2026-49478	SSRF and Token Leakage in Fulcio	9.1	Critical	78/100	CWE-918
CVE-2026-48592	Missing Authorization in Oban_web	7.5	High	78/100	CWE-862
CVE-2025-10996	Heap Buffer Overflow in SMILES Pa...	7.8	High	70/100	CWE-119
CVE-2026-48593	Memory Exhaustion in Oban_web Cron	7.5	High	68/100	CWE-400
CVE-2025-10995	Out-of-Bounds Write in Zipstream ...	7.8	High	65/100	CWE-787
CVE-2025-10994	Use-After-Free in GAMESS Molecule...	7.8	High	65/100	CWE-119
CVE-2026-3408	NULL Pointer Dereference in CDXML...	5.5	Medium	60/100	CWE-476
CVE-2026-2705	NULL Pointer Dereference in MOL2 ...	5.5	Medium	60/100	CWE-119
CVE-2026-48808	Sandbox Property Allowlist Bypass...	6.5	Medium	59/100	CWE-693
CVE-2026-48807	Sandbox Policy Bypass via Travers...	6.5	Medium	59/100	CWE-693
CVE-2026-48806	Sandbox Policy Bypass via Dynamic...	6.5	Medium	59/100	CWE-693
CVE-2026-50565	Insecure ServiceAccount Token Mou...	4.9	Medium	54/100	CWE-250
CVE-2026-49835	Memory Exhaustion in Sigstore Met...	5.9	Medium	53/100	CWE-770
CVE-2026-49820	Open Redirect via Path Normalizat...	6.1	Medium	52/100	CWE-601
CVE-2026-48796	Path Traversal in CefSharp Folder...	5.3	Medium	48/100	CWE-22
CVE-2026-2704	Out-of-Bounds Read in CIF Parser	3.3	Low	45/100	CWE-119
CVE-2026-55219	Race Condition in Paymenter Credi...	5.3	Medium	43/100	CWE-362
CVE-2026-48805	Sandbox State Regression in Inter...	2.7	Low	27/100	CWE-693

5. Detailed Vulnerability Findings

CVE-2026-50566

Finding: Privileged Pod Creation in Fission

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 99/100 | CWE: CWE-250

MITRE ATT&CK: T1611

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Attack Vector	Network
Privileges Required	High
Scope	Changed
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	High

Description:

Fission's runtime environment allows a security context bypass, enabling the creation of privileged pods. The failure to restrict container configuration allows attackers to escalate privileges by spawning pods with host-level access. This leads to complete cluster compromise.

Proof of Concept (PoC):

An attacker with restricted access to the Fission API modifies the SecurityContext of a runtime container builder configuration. By explicitly injecting `privileged: true` in the spec, the attacker bypasses standard admission controllers. The resulting pod is deployed with host-level capabilities, allowing the attacker to escape the container. This provides total control over the underlying Kubernetes nodes.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50566>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50566>

CVE-2026-48795**Finding: Incomplete Fix for Prototype Pollution in AdonisJS**

CVSS v3.1 Score: 9.4 | Severity: Critical | Urgency Score: 87/100 | CWE: CWE-1321

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	High

Description:

@adonisjs/bodyparser contains an incomplete fix for a prototype pollution vulnerability originally addressed in CVE-2026-25754. The validation logic fails to cover all possible nested JSON input patterns, allowing attackers to inject malicious properties into the global object. This can lead to application-wide state compromise or RCE.

Proof of Concept (PoC):

An attacker sends a POST request with a specially crafted JSON body containing `\_\_proto\_\_` fields to an endpoint using @adonisjs/bodyparser. The body parser fails to filter these fields effectively, allowing them to merge into the global Object prototype. The injected properties override existing functionality or default settings. This enables an attacker to manipulate server-side execution logic.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48795>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48795>

CVE-2026-49478**Finding: SSRF and Token Leakage in Fulcio**

CVSS v3.1 Score: 9.1 | Severity: Critical | Urgency Score: 78/100 | CWE: CWE-918

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Fulcio's OIDC discovery redirect logic is vulnerable to Server-Side Request Forgery (SSRF) and JWKS substitution. The failure to properly validate redirect targets allows attackers to manipulate identity provider paths. This can facilitate the leakage of Kubernetes service-account tokens.

Proof of Concept (PoC):

An attacker submits a crafted OIDC discovery request to the Fulcio service with an arbitrary redirect URL. The service follows the malicious redirect to an attacker-controlled endpoint that mimics a JWKS meta-issuer. By poisoning the cache, the attacker forces the service to validate tokens against the attacker's key. This results in the compromise of Kubernetes tokens and privilege escalation.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49478>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49478>

CVE-2026-48592

Finding: Missing Authorization in Oban_web

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 78/100 | CWE: CWE-862

MITRE ATT&CK: T1562

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

The oban_web application lacks sufficient authorization checks for the `save-job` event handler. The absence of a verification step allows unauthenticated or unauthorized users to perform sensitive job management actions. This results in unauthorized control over scheduled system background processes.

Proof of Concept (PoC):

An unauthenticated attacker sends a direct POST request to the application's `save-job` API endpoint. The backend handles the request without verifying the requester's identity or ownership permissions. The attacker can force the system to save malicious job definitions. This effectively leads to persistent task execution and potential system compromise.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48592>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48592>

CVE-2025-10996

Finding: Heap Buffer Overflow in SMILES Parser

CVSS v3.1 Score: 7.8 | Severity: High | Urgency Score: 70/100 | CWE: CWE-119

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Local
Privileges Required	None

Attack Complexity	Low
User Interaction	Required

Scope	Unchanged
Integrity Impact	High

Confidentiality Impact	High
Availability Impact	High

Description:

Open Babel's OBSmilesParser::ParseSmiles function is susceptible to a heap-based buffer overflow. The vulnerability is caused by improper bounds checking during the parsing of SMILES string inputs, allowing data to be written beyond the allocated buffer boundaries. This leads to potential memory corruption, which may result in arbitrary code execution or a denial-of-service condition depending on attacker-supplied input.

Proof of Concept (PoC):

A local attacker provides a malformed chemical SMILES file to the Open Babel parser. The OBSmilesParser::ParseSmiles function fails to validate the size of the input string against the stack allocation, leading to a heap overflow. The memory corruption allows an attacker to overwrite sensitive function pointers. The final impact is the potential execution of malicious code within the context of the user running the application.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2025-10996>

Ref: <https://www.cve.org/CVERecord?id=CVE-2025-10996>

CVE-2026-48593

Finding: Memory Exhaustion in Oban_web Cron

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

Oban_web's cron description feature is vulnerable to memory exhaustion due to unbounded range expansion. The application fails to limit the expansion of cron ranges before computing task schedules, leading to massive memory allocation. This facilitates a remote Denial of Service attack.

Proof of Concept (PoC):

An attacker provides a long, complex cron string with extensive range definitions to the Oban_web cron interface. The system attempts to expand this range fully into memory in a single pass. This leads to a spike in memory usage and eventually triggers an out-of-memory crash. The service becomes unresponsive to legitimate background task requests.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48593>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48593>

CVE-2025-10995

Finding: Out-of-Bounds Write in Zipstream Unzipper

CVSS v3.1 Score: 7.8 | Severity: High | Urgency Score: 65/100 | CWE: CWE-787

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Local
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

The zipstream basic_unzip_streambuf::underflow function in Open Babel performs an unsafe overlapping memory copy operation. The root cause is a failure to properly calculate source and destination boundaries when processing compressed streams, leading to an out-of-bounds write. This vulnerability may lead to data integrity compromise or potential system instability when processing crafted ZIP files.

Proof of Concept (PoC):

A user is induced to open a malicious ZIP file using the Open Babel toolkit. The basic_unzip_streambuf::underflow method attempts to process the stream, triggering a memcpy where memory ranges overlap incorrectly. This results in the overwriting of heap objects. Successful exploitation results in unintended system behavior or state manipulation.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2025-10995>
Ref: <https://www.cve.org/CVERecord?id=CVE-2025-10995>

CVE-2025-10994

Finding: Use-After-Free in GAMESS Molecule Reader

CVSS v3.1 Score: 7.8 | Severity: High | Urgency Score: 65/100 | CWE: CWE-119

MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Attack Vector	Local
Privileges Required	None
Scope	Unchanged
Integrity Impact	High

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	High
Availability Impact	High

Description:

The GAMESSOutputFormat::ReadMolecule function in Open Babel suffers from a Use-After-Free vulnerability. The root cause is the improper management of memory pointers during the parsing of GAMESS output files, where objects are referenced after being freed. This flaw allows an attacker to corrupt memory and potentially influence control flow.

Proof of Concept (PoC):

An attacker crafts a malicious GAMESS molecule file and triggers the import feature. The GAMESSOutputFormat::ReadMolecule function processes the file, freeing a memory block and subsequently attempting a second access. The attacker leverages the dangling pointer to gain arbitrary control over the process memory. This leads to potential remote code execution.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2025-10994>
Ref: <https://www.cve.org/CVERecord?id=CVE-2025-10994>

CVE-2026-3408

Finding: NULL Pointer Dereference in CDXML Parser

CVSS v3.1 Score: 5.5 | Severity: Medium | Urgency Score: 60/100 | CWE: CWE-476**MITRE ATT&CK: T1499****CVSS v3.1 Scoring Criteria:**

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Attack Vector	Local
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	None
Availability Impact	High

Description:

Open Babel's OBAAtom::GetExplicitValence function exhibits a NULL pointer dereference when processing CDXML files. The application fails to verify the existence of an atom object before accessing its properties, resulting in a system crash. This vulnerability can lead to a local denial-of-service attack.

Proof of Concept (PoC):

An attacker provides a malformed CDXML input file that lacks required atom node attributes. During processing, OBAAtom::GetExplicitValence is called on an uninitialized atom pointer. The program crashes immediately due to the dereference attempt, terminating the service. This allows for simple resource exhaustion through file input.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-3408>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-3408>**CVE-2026-2705****Finding: NULL Pointer Dereference in MOL2 Parser****CVSS v3.1 Score: 5.5 | Severity: Medium | Urgency Score: 60/100 | CWE: CWE-119****MITRE ATT&CK: T1499****CVSS v3.1 Scoring Criteria:**

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:N/I:N/A:H

Attack Vector	Local
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	None
Availability Impact	High

Description:

The OBAAtom::SetFormalCharge function within the Open Babel MOL2 reader is susceptible to a NULL pointer dereference. The flaw occurs because the input reader fails to ensure that the atomic object has been successfully instantiated before calling the charge assignment method. This condition causes an application exception and potential crash when processing crafted MOL2 data.

Proof of Concept (PoC):

A user attempts to parse a malformed MOL2 file containing an undefined atom record. The parser initiates a call to OBAAtom::SetFormalCharge on a null pointer destination. The process faults and shuts down, denying service to other valid tasks. The attacker gains the ability to interrupt chemistry processing workflows.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-2705>Ref: <https://www.cve.org/CVERecord?id=CVE-2026-2705>

CVE-2026-48808

Finding: Sandbox Property Allowlist Bypass in Twig

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-693

MITRE ATT&CK: T1212

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

Twig's Sandbox implementation contains a bypass vulnerability in the SourcePolicyInterface when handling the `column` filter. The root cause is insufficient verification of filter inputs against the configured allowlist, permitting unauthorized access to restricted object properties. This allows an attacker to access sensitive internal data or bypass template restrictions.

Proof of Concept (PoC):

An attacker submits a specially crafted template string utilizing the `column` filter. The Twig Sandbox fails to validate the filter usage against the strict property allowlist defined in SourcePolicyInterface. As a result, the engine evaluates properties that should be hidden. The attacker successfully extracts internal application data normally restricted by the sandbox.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48808>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48808>

CVE-2026-48807

Finding: Sandbox Policy Bypass via Traversable Filters

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-693

MITRE ATT&CK: T1212

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

The Twig sandbox fails to enforce `\_\_toString()` policies when using `Traversable` objects within `join` and `replace` filters. The root cause is a failure in the internal security validator to traverse the object's interface and detect insecure method calls. An attacker can use this flaw to invoke restricted methods or access unauthorized data.

Proof of Concept (PoC):

An attacker creates a template that passes a `Traversable` object into the `join` filter. The sandbox engine fails to apply the security policy before the `\_\_toString()` method is implicitly triggered. This allows the attacker to execute arbitrary string conversions on objects. This results in the leakage of restricted object states to the rendered page.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48807>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48807>

CVE-2026-48806

Finding: Sandbox Policy Bypass via Dynamic Mapping

CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-693

MITRE ATT&CK: T1212

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	Low

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

Twig's sandbox mechanism is susceptible to a `\_\_toString()` policy bypass through dynamic mapping keys. The vulnerability arises from improper validation of keys used within object mappings, allowing access to methods that are nominally blocked by the security sandbox. An attacker can leverage this to bypass restricted runtime constraints.

Proof of Concept (PoC):

The attacker provides a template containing dynamically mapped array keys targeting restricted methods. The Twig engine fails to inspect the object access correctly during the dynamic resolution phase. The attacker successfully invokes prohibited `\_\_toString()` methods. The final impact is the unauthorized access to sensitive object representations.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48806>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48806>

CVE-2026-50565

Finding: Insecure ServiceAccount Token Mounting in Fission

CVSS v3.1 Score: 4.9 | Severity: Medium | Urgency Score: 54/100 | CWE: CWE-250

MITRE ATT&CK: T1528

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:N/A:N

Attack Vector	Network
Privileges Required	High
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	High
Availability Impact	None

Description:

Fission builder pods incorrectly auto-mount the `fission-builder` ServiceAccount token into user-supplied builder containers. This design flaw permits unauthorized access to sensitive service-level resources if the container is compromised. The exposure of this token provides attackers with excess privileges within the cluster.

Proof of Concept (PoC):

The user supplies a build container specification to Fission that is executed on the builder pod. The pod automatically

mounts the system's `fission-builder` ServiceAccount token as a secret in the builder container's filesystem. An attacker who has achieved code execution in the builder container can read this token. The attacker can then use the token to query the Kubernetes API.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-50565>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-50565>

CVE-2026-49835

Finding: Memory Exhaustion in Sigstore Metric Cardinality

CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-770

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:N/I:N/A:H

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	High
User Interaction	None
Confidentiality Impact	None
Availability Impact	High

Description:

The Sigstore Timestamp Authority is vulnerable to OOM (Out of Memory) conditions caused by unbounded metric label cardinality. The system fails to sanitize incoming labels before processing, leading to the rapid consumption of system memory. An attacker can exploit this to perform a Denial of Service attack against the authority service.

Proof of Concept (PoC):

An unauthenticated attacker sends a flood of requests with randomly generated high-cardinality metric labels to the Sigstore service. The monitoring component attempts to store these unique labels in memory, triggering excessive resource usage. The service eventually exhausts available RAM and crashes. This prevents legitimate timestamping operations.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49835>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49835>

CVE-2026-49820

Finding: Open Redirect via Path Normalization

CVSS v3.1 Score: 6.1 | Severity: Medium | Urgency Score: 52/100 | CWE: CWE-601

MITRE ATT&CK: T1204

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N

Attack Vector	Network
Privileges Required	None
Scope	Changed
Integrity Impact	Low

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

Probo is vulnerable to an open redirect attack resulting from improper path normalization. The application fails to validate the destination URL properly after normalization, allowing attackers to redirect users to arbitrary external

domains. This facilitates phishing and credential harvesting attacks.

Proof of Concept (PoC):

An attacker crafts a URL containing a target path and an arbitrary external URL parameter, using normalization tricks to bypass current redirect filters. When a user clicks the URL, the Probo application fails to detect the redirection to an external domain. The user is redirected to an attacker-controlled phishing page. This results in the compromise of user-sensitive data.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-49820>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-49820>

CVE-2026-48796

Finding: Path Traversal in CefSharp FolderSchemeHandler

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 48/100 | CWE: CWE-22

MITRE ATT&CK: T1083

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Network
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	None
Confidentiality Impact	Low
Availability Impact	None

Description:

CefSharp.Common's FolderSchemeHandlerFactory contains a path boundary check flaw, exposing files outside the configured root folder. The code fails to properly normalize paths before file access, allowing access to unauthorized system areas via path traversal techniques. This results in an increased risk of sensitive information disclosure.

Proof of Concept (PoC):

An attacker constructs a URI using dot-dot-slash notation relative to the folder scheme handler. The FolderSchemeHandlerFactory fails to strip these sequences and resolves the path to system-level directories. The service then serves files from the unauthorized directory to the requester. This leads to the exposure of local system files.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48796>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48796>

CVE-2026-2704

Finding: Out-of-Bounds Read in CIF Parser

CVSS v3.1 Score: 3.3 | Severity: Low | Urgency Score: 45/100 | CWE: CWE-119

MITRE ATT&CK: T1592

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N

Attack Vector	Local
Privileges Required	None
Scope	Unchanged
Integrity Impact	None

Attack Complexity	Low
User Interaction	Required
Confidentiality Impact	Low
Availability Impact	None

Description:

Open Babel's transform3d::DescribeAsString function allows for an out-of-bounds read when processing CIF files. The root cause is a failure to properly handle string termination during the conversion of 3D transformation matrices. This could allow an attacker to potentially leak sensitive memory contents.

Proof of Concept (PoC):

An attacker creates a malicious CIF file that defines invalid 3D coordinate strings. When loaded, transform3d::DescribeAsString attempts to read past the end of the string buffer. The function exposes adjacent memory bits in the application output, leaking data. This allows for information gathering by the attacker.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-2704>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-2704>

CVE-2026-55219**Finding: Race Condition in Paymenter Credit Handler**

CVSS v3.1 Score: 5.3 | Severity: Medium | Urgency Score: 43/100 | CWE: CWE-362

MITRE ATT&CK: T1558

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:U/C:N/I:H/A:N

Attack Vector	Network
Privileges Required	Low
Scope	Unchanged
Integrity Impact	High

Attack Complexity	High
User Interaction	None
Confidentiality Impact	None
Availability Impact	None

Description:

Paymenter's payWithCredit() function is vulnerable to a race condition that enables credit double-spending. The lack of atomic locking mechanisms ensures that concurrent requests can manipulate account balances before the transaction completes. This results in the compromise of financial integrity for the affected platform.

Proof of Concept (PoC):

An authenticated user sends multiple rapid, concurrent requests to the payment endpoint calling payWithCredit(). Because the application lacks row-level locking on the user's credit balance, both transactions validate the balance simultaneously. The system commits both requests, effectively spending the same credit multiple times. This leads to the duplication of digital assets.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-55219>

Ref: <https://www.cve.org/CVERecord?id=CVE-2026-55219>

CVE-2026-48805**Finding: Sandbox State Regression in Internal Wrappers**

CVSS v3.1 Score: 2.7 | Severity: Low | Urgency Score: 27/100 | CWE: CWE-693

MITRE ATT&CK: T1212

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:L/I:N/A:N

Attack Vector	Network
Privileges Required	High

Attack Complexity	Low
User Interaction	None

Scope	Unchanged	Confidentiality Impact	Low
Integrity Impact	None	Availability Impact	None

Description:

A regression in Twig's internal wrappers found in `src/Resources/core.php` weakens the sandbox security state. The issue stems from deprecated code paths that bypass new security checks, leaving older configurations vulnerable to property access violations. An attacker can utilize these paths to read internal data.

Proof of Concept (PoC):

A user with administrative privileges accesses a template path that hits the deprecated wrapper code in core.php. Because the old code path does not enforce current sandbox rules, the user can access restricted object metadata. This vulnerability allows the user to inspect system internals that should remain protected. It lowers the overall security baseline of the template environment.

Ref: <https://nvd.nist.gov/vuln/detail/CVE-2026-48805>
Ref: <https://www.cve.org/CVERecord?id=CVE-2026-48805>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from the GitHub Advisory Database and cross-references active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. All CVE identifiers, CVSS scores, and CWE mappings are sourced directly from official databases and are verifiable via the references provided in Section 5. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- GitHub Advisory Database -- <https://github.com/advisories>
- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>